Informe de seguridad — Sistema de Conduces VMO

Auditoría previa a la publicación en internet · 7 de octubre de 2026 · Referencia: OWASP ASVS 5.0

0	8	4	886
críticos	altos — todos arreglados	PRs de arreglo (#107, #108, #110, #111)	pruebas automáticas en verde

Alcance

Se revisó todo el código de la app (FastAPI, 3 módulos, ~14.000 líneas) en tres frentes: **login, sesiones y permisos**; **inyección, archivos y gasto**; y **navegador, claves y librerías**. Cada hallazgo grave se confirmó leyendo el código y, cuando se pudo, reproduciéndolo. Cada arreglo tiene pruebas automáticas que fallan si se deshace.

Hallazgos altos — arreglados

#	Hallazgo	Riesgo una vez publicada	Arreglo
1	El cuerpo de los pedidos se leía antes de revisar el login	Un anónimo podía subir varios GB y llenar el disco o la memoria	Revisión de sesión y tope de tamaño antes de leer nada (#107)
2	Una sola cuenta con contraseña de 6 caracteres; con las variables vacías se entraba sin contraseña	Acceso por fuerza bruta o por error de configuración	En producción la app no arranca con credenciales débiles; nunca acepta un login en blanco; comparación en tiempo constante; sesión de 256 bits (#107)
3	El bloqueo por intentos fallidos se rompía detrás del proxy	O bloqueaba a toda la empresa, o dejaba de existir	IP real detrás del proxy y bloqueo global además del de IP (#107)
4	Logística metía el texto de los Excel sin escapar en la página	Un Excel con código escondido se ejecutaba en el navegador de quien abriera el día y robaba su sesión	Todo texto de datos se escapa; probado con un Excel trampa: aparece como texto en 22 lugares, no se ejecuta en ninguno (#108)
5	Librería de Excel de Logística vulnerable (SheetJS 0.18.5, CVE-2023-30533 y CVE-2024-22363) cargada de un CDN	Un Excel armado podía alterar la página	SheetJS 0.20.3 servida desde la propia app (#108)
6	Sin topes de gasto en Anthropic (chat sin fin de vueltas, reprocesos en	Cientos de dólares por lote con una sesión robada o un error	Máximo 3 páginas por PDF, 5 vueltas en el chat, un reproceso a la vez, historial acotado (#110)

	paralelo, PDFs de cualquier largo)		
7	Los lotes de estimaciones quedaban en memoria para siempre; el trabajo pesado congelaba el servidor	Caída del servidor con 2–3 lotes grandes; la app se congelaba para todos	Los lotes vencen a las 2 h (máximo 5); Excel, ZIP y chat en hilos aparte (#110)
8	Lo que devolvía Vision se guardaba sin filtrar	Un PDF manipulado podía hacer entrar una factura como "aprobada a mano"	Solo se aceptan los campos esperados, con su tipo; cantidades imposibles son error y reintento (#111)

Hallazgos medios y bajos — arreglados

Nivel	Hallazgo	Arreglo
Medio	Sin cabeceras de seguridad (CSP, anti-iframe, HSTS)	Agregadas; la CSP impide mandar datos a otro sitio (#107, #108)
Medio	`/docs` publicaba el mapa de la API	Apagado en producción (#107)
Medio	Fechas sin validar en nombres de archivo (escritura fuera de la carpeta)	Solo `AAAA-MM-DD` (#107)
Medio	Fórmulas en los Excel generados (`=WEBSERVICE(…)`)	Se guardan como texto (#111)
Bajo	Reportes HTML sin escapar	Escapados (#111)
Bajo	La descarga de Excel permitía bajar la base de datos	Solo los Excel de validación (#111)
Bajo	Nombre de PDF con salto de línea; borrado con nombre sin validar; XML de .xlsx sin `defusedxml`	Corregidos (#111)

Lo que está bien

- **Sin inyección SQL: todas las consultas usan parámetros.**
- **Ninguna clave en los 259 commits del historial; el `.env` nunca se subió.**
- **Las 29 rutas de datos exigen sesión; las descargas bloquean rutas fuera de su carpeta.**
- **LibreOffice se llama sin shell y con tiempo límite; ZIP con topes reales de descompresión.**

Lo que queda en manos de quien instala

> 1. **Contraseña de 15 caracteres o más** y `PRODUCCION=1` (la app no arranca sin eso).
> 2. **HTTPS** delante de la app; el puerto de uvicorn no queda expuesto.
> 3. **Tope de gasto mensual en la consola de Anthropic.**
> 4. **Un solo proceso** de uvicorn (`--workers 1`).
> 5. **Backups diarios** copiados fuera del servidor.

Pendiente para más adelante (no bloquea la publicación)

- **Una cuenta por persona**, con roles. Hoy hay una sola cuenta compartida: no queda registro de quién aprobó, cerró o cargó cada cosa, y quitarle el acceso a alguien obliga a cambiar la contraseña de todos.
- La sesión vive en el almacenamiento del navegador. Con el escape y la CSP el riesgo es bajo; pasarla a cookie `HttpOnly` lo cierra del todo.
- Correr `pip-audit` periódicamente sobre `requirements.txt`.